

NOTE TECHNIQUE D'INGÉNIERIE

Vecteurs d'Évasion EDR & Architecture de Durcissement

AUTEUR

Agilly Cyberdéfense

PUBLIC CIBLEResponsables SOC, DFIR,
ingénieurs sécurité**VERSION**

v1.0 du 15 septembre 2026

PÉRIMÈTRE

Postes de travail et serveurs Windows : Windows 10 22H2, Windows 11 22H2+, Windows Server 2016 et ultérieur.
Hors périmètre : hyperviseurs (ESXi), Linux, consoles de sauvegarde et d'administration.

Ce document décrit un **socle de durcissement mesurable**. Un socle conforme réduit la surface d'attaque ; il ne garantit pas qu'un agent ne puisse être neutralisé. La validation de la **résistance effective** relève d'un test contrôlé en environnement isolé, distinct du présent audit de socle.

1. Contexte opérationnel

Un agent EDR observe le système depuis deux positions : en **espace utilisateur**, par injection de bibliothèques dans les processus pour intercepter les appels système sensibles ; en **mode noyau**, par enregistrement de routines de notification (*kernel callbacks*) qui signalent la création de processus, le chargement d'images mémoire et l'ouverture de descripteurs d'accès. Les techniques de la section 2 visent ces deux positions, non les moteurs de détection.

Le déplacement est documenté : AuKill (Sophos X-Ops, avril 2023) détourne un pilote signé légitime pour terminer des processus de sécurité ; EDRKillShifter (août 2024, groupe RansomHub) sélectionne dynamiquement un pilote vulnérable selon la protection rencontrée. Références à la section 6. En exploitation, la rupture ne se présente pas comme une alerte mais comme une absence de données, souvent qualifiée en incident de connectivité, d'où la section 5.

Deux prérequis déplacent le centre de gravité. L'évasion noyau suppose des **privilèges administrateur local ou SYSTEM déjà acquis** (axe 1 de la section 3). Et le point d'entrée dominant reste la **compromission d'identité**, puis d'une console d'administration exposée **sans MFA** : section 2.D, hors périmètre de l'audit local.

2. Analyse des vecteurs d'évasion critiques



A. Exploitation par pilotes vulnérables (BYOVD, *Bring Your Own Vulnerable Driver*)

Windows impose la signature numérique de tout pilote chargé en mode noyau (*Driver Signature Enforcement, DSE*). L'attaquant ne contourne pas cette règle : il l'exploite.

- Il implante un pilote **officiel, légitimement signé** et validé par Microsoft (souvent un ancien utilitaire de diagnostic matériel), qui embarque une faille documentée offrant une primitive de lecture/écriture arbitraire en Ring 0.
- Il manipule alors directement les structures internes du noyau (*Direct Kernel Object Manipulation, DKOM*) : décrochage des routines de rappel (`PsSetCreateProcessNotifyRoutine`, `ObRegisterCallbacks`), altération des tables d'accès, terminaison des threads des processus protégés.

Point de durcissement à retenir : cette chaîne n'exécute pas de code non signé, elle **satisfait** le DSE et manipule des **données** noyau. Cela a une conséquence directe sur la matrice de la section 3 : HVCI protège l'intégrité du *code*, pas des *données*, et n'arrête donc pas cette chaîne (voir section 3, axe 2, et la donnée de référence en section 6).

Deux traces exploitables subsistent et sont contrôlées par l'audit : le pilote déposé reste identifiable par son empreinte, et l'assaillant l'efface fréquemment du disque après chargement, un module chargé dont le fichier a disparu est un indicateur en soi.

Outils répertoriés : AuKill, EDRKillShifter, Terminator, RealBlindingEDR.

B. Neutralisation des points d'instrumentation (ETW & AMSI)

ETW (*Event Tracing for Windows*) est un mécanisme de **traçage d'événements**, non une « télémétrie mémoire ». **AMSI** (*Antimalware Scan Interface*) expose aux moteurs d'analyse le contenu des scripts et du code chargé dynamiquement (PowerShell, macros, .NET). Dans un processus qu'il contrôle, l'assaillant patche en mémoire le stub `EtwEventWrite` et l'entrée AMSI (retour immédiat, opcode `0xc3`) : le code s'exécute sans être analysé et **sans alerte comportementale**. Durcissement : axe 5 de la section 3.

C. Abus des mécanismes d'administration (*Living off the Land*)

- **Désynchronisation logicielle** : exploitation des fenêtres de mise à niveau ou de rétrogradation d'agents pour interrompre l'exécution avant la réinitialisation de l'anti-sabotage.
- **Détournement des outils natifs** : usage de `gpscript.exe`, `wmic.exe`, `sc.exe` avec des privilèges administratifs pour désactiver la protection ou injecter des exclusions.
- **Redémarrage en mode sans échec** : contournement classique de l'anti-sabotage, les services de sécurité n'y étant pas tous démarrés.

D. Compromission de la console d'administration

Vecteur distinct, et souvent **le premier** : l'accès à la console de gestion de l'EDR par identifiants d'administrateur volés, en **l'absence de MFA**. Il permet de créer des exclusions globales, de désactiver l'anti-sabotage ou de désinstaller l'agent proprement, à l'échelle du tenant, **sans aucune exploitation technique**. Ce risque est majeur pour tout environnement multi-tenant et impose MFA, moindre privilège et journalisation des actions d'administration. Il sort du périmètre mesurable côté poste : aucun contrôle local ne le détecte, ce qui en fait un point de revue d'architecture et non d'audit de socle.

3. Matrice de durcissement opérationnel

L'élévation du niveau de résistance exige l'activation conjointe des mécanismes suivants, organisés par axe. La colonne *Limite / condition* énonce ce que chaque mesure ne couvre pas, condition d'un déploiement honnête.

Axe 1. Privilèges & socle (le premier maillon)		
Mécanisme	Action de durcissement	Limite / condition
Administrateurs locaux	Restreindre l'appartenance ; proscrire comptes de service et utilisateurs en admin local.	Mesure la moins coûteuse, c'est elle qui fait s'effondrer toute la chaîne de la section 2.
LAPS	Mots de passe administrateur local uniques, gérés et renouvelés.	Aucune réserve particulière.
UAC	Élévation avec consentement ; interdiction de la désactivation.	Aucune réserve particulière.
Secure Boot	Chaîne de démarrage vérifiée dès le firmware.	Prérequis : UEFI, absence de CSM.
Options de démarrage du noyau	Proscrire testsigning, nointegritychecks et le débogage noyau en production.	Un poste laissé en <i>test-signing</i> accepte un pilote non signé : la chaîne de la section 2 n'a même plus besoin d'un pilote vulnérable.
Protection DMA du noyau	Bloquer l'accès mémoire direct par les ports externes.	Prérequis matériels ; complémentaire de VBS.
Démarrage en mode sans échec	Bloquer / superviser le boot en mode sans échec.	Contournement fréquent de l'anti-sabotage, souvent oublié.

Axe 2. Anti-BYOVD : empêcher le chargement, contraindre l'exécution, détecter le déjà-présent

Mécanisme	Action de durcissement	Limite / condition
Microsoft Vulnerable Driver Blocklist	Bloquer les pilotes vulnérables connus (profil MDM/Intune ou GPO).	Liste mise à jour lentement et contournable par une variante recompilée du même pilote.
WDAC par signataire (cible, politique auditée)	N'autoriser que des pilotes explicitement approuvés.	Contrôle préventif de référence. Coût de mise en œuvre ; phase d'audit requise. La politique en vigueur est lue et restituée par l'audit.
Inventaire par empreinte des pilotes tiers (référentiel Agilly)	Détecter un pilote vulnérable déjà installé , angle mort de l'ASR et de la blocklist.	Détection d'un échantillon précis ; non préventif (cf. section 6).
Validité de signature des pilotes chargés	Vérifier qu'aucun pilote en exécution ne porte une signature non valide.	Contrôle de détection ; une signature valide ne dit rien de la vulnérabilité du pilote.
Pilotes et minifiltres en exécution sans fichier sur disque	Relever les modules chargés dont le fichier a disparu.	Indicateur d'évasion, non de durcissement : le mode opératoire de la section 2.A prévoit l'effacement du pilote après chargement.
VBS + HVCI	Intégrité du code exécuté en Ring 0.	HVCI protège l'intégrité du code, pas des données noyau . Il ne bloque ni un pilote signé valide ni la manipulation DKOM. Preuve empirique : le sous-ensemble du référentiel Agilly annoté « chargé avec HVCI actif » (section 6).
Règle ASR « pilotes signés vulnérables exploités »	Empêcher l'écriture du pilote sur le disque.	Ne bloque pas un pilote déjà présent. Inapplicable si Defender n'est pas l'antivirus actif (basculer en mode passif dès qu'un agent tiers est en protection primaire).

Axe 3. Isolement des secrets		
Mécanisme	Action de durcissement	Limite / condition
LSA Protection (RunAsPPL)	Exécuter Lsass.exe en <i>Protected Process Light</i> contre l'injection et la lecture mémoire.	Contournable par BYOVD ; casse certains fournisseurs d'authentification et outils DLP, d'où un déploiement en mode audit obligatoire d'abord .
Credential Guard (VBS)	Isolement des secrets d'authentification par virtualisation.	Prérequis matériels ; incompatibilités à vérifier au préalable.

Axe 4. Intégrité de l'agent		
Mécanisme	Action de durcissement	Limite / condition
Tamper Protection	Anti-sabotage activé et verrouillé côté console, non modifiable localement.	Doit être piloté centralement.
Verrou de désinstallation	Mot de passe centralisé / double validation.	Standard de forte maturité, à atteindre par paliers.
Protection temps réel & fraîcheur des signatures	Surveillées en continu.	Aucune réserve particulière.

Axe 5. Visibilité mémoire & scripts (réponse à la section 2.B)		
Mécanisme	Action de durcissement	Limite / condition
ETW-TI (Threat Intelligence)	Traçage protégé, résistant au patch ETW en espace utilisateur.	Aucune réserve particulière.
Fournisseurs AMSI à jour	Analyse du contenu dynamique (scripts, macros, .NET).	Aucune réserve particulière.
Journalisation ScriptBlock + modules, transcription	Tracer l'exécution PowerShell.	Filet de sécurité utile, non inviolable : le patch d'EtwEventWrite en mémoire réduit la portée de la journalisation dans le processus concerné.
Désactivation de PowerShell v2	Supprimer un moteur dépourvu d'AMSI et de journalisation.	Aucune réserve particulière.
Mode de langage restreint (<i>cible</i>)	Réduire la surface d'exécution de script.	Impact applicatif à valider.

Axe 6. Télémétrie & collecte indépendante

Mécanisme	Action de durcissement	Limite / condition
Rattachement console + export SIEM	Corrélation centralisée de la télémétrie.	Le rattachement déclaré localement ne prouve pas la remontée : les deux points sont contrôlés séparément.
Exclusions antivirus	Inventorier et justifier chaque exclusion.	Vecteur d'aveuglement le moins coûteux pour un attaquant disposant de la console (section 2.D).
Collecteur d'événements indépendant (WEF)	Collecter les journaux hors de l'agent.	Prérequis d'architecture : un agent neutralisé ne remonte plus ses propres journaux, sans collecte hors agent, la preuve de la neutralisation disparaît avec l'agent.
Rétention du journal Sécurité	Dimensionner la rétention pour couvrir la fenêtre d'investigation.	Une rétention courte réduit la portée de l'axe 7.

Axe 7. Traces et historique (30 jours)

Les six axes précédents photographient un état à l'instant T. **Une machine dont la protection a été désactivée puis réactivée présente un état conforme et une histoire qui ne l'est pas.**

Mécanisme	Action de durcissement	Limite / condition
Arrêts de services de sécurité	Relever les arrêts et plantages sur 30 jours.	Ne couvre pas la terminaison depuis le noyau (section 2.A), qui ne transite pas par le gestionnaire de services.
Désactivations de protection	Relever les désactivations de protection temps réel et d'anti-sabotage.	Dépend de la journalisation de l'éditeur en place.
Installation de pilotes noyau	Relever les nouveaux services de type pilote.	Le bruit légitime (mises à jour, pilotes matériels) doit être qualifié.
Refus de chargement de pilotes	Relever les refus opposés par l'intégrité du code.	Signal de valeur : une tentative bloquée est une tentative.
Intégrité des journaux	Détecter un effacement du journal Sécurité.	L'effacement est lui-même l'événement le plus significatif.
Collecteur indépendant (WEF)	Vérifier l'existence d'un abonnement réel de collecte hors agent.	Sans lui, cet axe disparaît en même temps que la machine.

La fenêtre est bornée par la rétention configurée du journal, ce qui fait de cette rétention un point de durcissement à part entière (axe 6).

4. Script d'audit de conformité socle

L'évaluation de ce socle est outillée par un script PowerShell d'audit en libre accès, publié sur GitHub, <https://github.com/AGILLY-BU-CYBERDEFENSE/audit-evasion-edr>. Il s'exécute en lecture seule et peut être relu intégralement avant toute exécution.

- **Objet** : évaluer, en lecture seule, l'état du socle de durcissement d'un poste Windows au regard des vecteurs ci-dessus.
- **Couverture** : plusieurs dizaines de contrôles techniques, regroupés en huit familles dans le rapport : socle firmware, intégrité noyau, anti-BYOVD, intégrité de l'agent, télémétrie, historique des journaux, privilèges, réduction de surface. Ces familles ne recouvrent pas exactement les axes de la section 3 : la section 3 organise des **mesures de durcissement**, le rapport organise des **contrôles mesurables**. L'axe 3 est ainsi restitué dans la famille « intégrité noyau ». L'inventaire anti-BYOVD couvre tous les pilotes noyau en exécution qui ne sont pas édités par Microsoft, **y compris ceux signés WHQL ou par attestation** : le sujet de ces certificats porte 0=Microsoft Corporation alors qu'il s'agit de pilotes tiers contresignés, la classe même qu'exploite le BYOVD. Les minifiltres non enregistrés comme services sont comparés séparément.
- **Verdicts** : CONFORME, CONFORME (PRÉSUMÉ), NON CONFORME, INDÉTERMINÉ, NON APPLICABLE (ex. ligne ASR quand Defender est passif), CONFIGURÉ (NON ACTIF), INFORMATION, À VÉRIFIER EN CONSOLE.

- **Innocuité** : lecture seule du système, aucun appel réseau, aucune donnée ne quitte la machine. Les seules écritures sont les livrables, dans le profil utilisateur.
- **Référentiel d'empreintes** : le fichier AGILLY_LOLDrivers_Empreintes.csv se place dans le dossier du script, qui le détecte seul. Il est facultatif : sans lui, la correspondance d'empreintes sort en INDÉTERMINÉ et les autres contrôles sont inchangés.
- **Restitution** : rapport HTML autonome (feuille d'impression prévue pour un PDF propre), export CSV pour consolidation de parc, corrélation MITRE ATT&CK par contrôle.

Lecture des résultats

À vérifier en console. Cet état désigne un point qui ne peut être tranché que depuis la console de l'éditeur. Il ne pénalise ni le score ni la couverture d'audit : un poste sous agent tiers n'est pas artificiellement dégradé par rapport à un poste sous Defender for Endpoint, dont certains états sont lisibles localement.

Couverture d'audit. Le rapport affiche, distinctement du score, la proportion de contrôles réellement évalués. **Un « aucun écart » obtenu sur une couverture faible n'est pas un état sain** : sous le seuil, l'audit est déclaré non concluant et le code de sortie le signale, afin qu'un résultat partiel ne soit jamais restitué comme une conformité. En consolidation de parc, la couverture se lit toujours avec le verdict.

Lecture ATT&CK. Chaque contrôle porte les identifiants de technique qu'il contraint ou dont il détecte la trace. Le rattachement qualifie le contrôle, pas la machine : il ne signifie pas que la technique a été observée sur le poste audité.

Hypothèse de validité. Les contrôles lisent l'état de la machine par les interfaces que Windows expose : registre, WMI, gestionnaire de services, journaux, variables de firmware relayées par le noyau. C'est donc le système audité qui rend son propre verdict, *a fortiori* pour HVCI, Credential Guard et la protection LSA, dont l'état est rapporté à travers le noyau qu'ils décrivent. C'est la limite de tout audit en ligne, non une faiblesse de l'outil : établir qu'une machine n'est pas compromise suppose une analyse hors ligne ou une télémétrie collectée ailleurs (axe 6). L'outil répond à « mon socle est-il durci ? », jamais à « ai-je été compromis ? ».

Prérequis et intégrité

Prérequis d'exécution. Windows 10 / Server 2016 ou ultérieur, PowerShell 5.1, console 64 bits (une console 32 bits sur un système 64 bits fausse l'inventaire des pilotes ; le script le détecte et le signale), session élevée. L'inventaire des pilotes noyau ajoute 20 à 60 secondes.

Intégrité des livrables. Script et référentiel sont publiés avec leur empreinte SHA256 et un fichier .sha256 adjacent, que le script reprend pour vérifier la liste avant usage : une liste tronquée ferait autrement ressortir tous les pilotes comme sains. Cette vérification atteste l'intégrité au transport, non l'authenticité : qui remplace le fichier remplace l'empreinte posée à côté. Pour l'authenticité, comparer aux valeurs ci-dessous.

Fichier	SHA256
Audit-SocleEvasionEDR-v1.ps1	a9bf90f3b0cbd8112631c2e7e9313b4b3eda4afb2a788f6d50113e908f5853f9
AGILLY_LOLDrivers_Empreintes.csv	8068aba6cd9167a898f530f2d5212be0a7bc0290b0320e33cb76b673075b0c2c

Comportement attendu côté EDR. Le script énumère les pilotes noyau chargés et calcule leurs empreintes ; une alerte de votre agent sur cette activité est normale et attendue. Aucun binaire n'est déposé, aucun pilote n'est chargé, aucune connexion réseau n'est ouverte.

5. Exigences d'ingénierie SOC : gestion des ruptures de télémétrie

La détection d'une neutralisation d'agent repose sur la surveillance des signaux faibles d'infrastructure. Trois règles, avec les conditions techniques que chacune suppose.

1. Règle de corrélation sur perte de signal (heartbeat) : des seuils segmentés

- **Serveurs de production** : alerte de sévérité haute au-delà de 15 min de silence sans maintenance programmée (seuil tenable).
- **Postes fixes** : seuil adapté aux plages d'exploitation.
- **Postes nomades** : ne pas alarmer sur un seuil brut (veille, VPN, déplacements), corréler l'absence de signal EDR avec un signal d'activité indépendant (authentification, présence réseau).

Faisabilité par plateforme : le seuil natif d'inactivité de MDE se compte en jours. Une détection à 15 min suppose une requête *Advanced Hunting* périodique ou une collecte API, un pipeline SIEM et une supervision continue, donc un développement spécifique à chaque plateforme.

2. Surveillance des événements de désenregistrement : portée réelle

Les Event ID 7036 / 7040 signalent l'arrêt ou l'altération d'un service : ils couvrent la section 2.C. Ils **ne couvrent pas** la terminaison depuis le noyau (section 2.A), qui ne transite pas par le gestionnaire de services et ne génère aucun 7036/7040. Prérequis d'architecture associé : un collecteur indépendant (WEF), un agent mort ne transmettant plus ses journaux.

Le script d'audit exploite déjà cette famille d'événements en lecture rétrospective sur 30 jours : arrêt de service de sécurité (7036 / 7040), installation d'un service de type pilote (7045), désactivation de protection côté Defender, refus de chargement opposé par l'intégrité du code, effacement du journal Sécurité (1102). **C'est un point d'entrée sans SIEM** : ce qui est ici constaté a posteriori sur une machine est ce que la règle de corrélation doit voir en temps réel sur le parc.

3. Réponse automatisée (SOAR), garde-fous obligatoires

Sans garde-fous, une panne de console éditeur ou une coupure WAN isolerait le parc entier d'un client. La règle exige : fenêtres de maintenance, listes d'exclusion, plafond d'isolations par heure, validation humaine au-delà d'un seuil, autorisation contractuelle. L'isolation par port ou VLAN suppose par ailleurs un NAC déployé.

6. Références et sources publiques

4 319 empreintes de pilotes annotées comme chargées **malgré HVCI actif**

Référentiel consolidé au 14/09/2026 : **6 849 empreintes uniques** de pilotes vulnérables. Le décompte porte sur des **empreintes de fichier** (SHA256, SHA1, MD5), un même pilote peut contribuer jusqu'à trois entrées selon les algorithmes disponibles en amont : le total est donc supérieur au nombre d'échantillons recensés par les sources, qui comptent par pilote.

Le sous-ensemble annoté « se charge malgré HVCI » est la **démonstration empirique** de la limite d'HVCI face au BYOVD (section 3, axe 2). La correspondance par empreinte est un contrôle de **détection** ; le contrôle **préventif** reste WDAC par signataire, une autre version compilée du même pilote passe au travers de la comparaison d'empreintes.

Sources de la liste publiée : LOLDrivers (loldrivers.io) et la transformation lisible par machine de la Microsoft Vulnerable Driver Blocklist. MalwareBazaar est désactivé par défaut dans l'outil de collecte et n'entre pas dans la

liste publiée. La colonne sources du CSV conserve la provenance de chaque entrée, ce qui permet de retracer une correspondance contestée. Actualisation prévue : trimestrielle.

Sophos X-Ops

- « *AuKill EDR killer malware abuses Process Explorer driver* » (avril 2023), neutralisation de processus de sécurité via un pilote signé Sysinternals détourné.
- « *Ransomware attackers introduce new EDR killer to their arsenal* » (août 2024), chargeur EDRKillShifter et orchestration dynamique de pilotes vulnérables (groupe RansomHub).

Mandiant Threat Intelligence (Google Cloud)

- « *Bring Your Own Vulnerable Driver (BYOVD) Attacks* », panorama des vecteurs d'attaque au niveau noyau et de l'exploitation des failles de signature tierce.

Projet LOLDrivers (*Living Off The Land Drivers*)

- *loldrivers.io*, référentiel public des pilotes signés vulnérables, empreintes hachées et règles de détection ; base du référentiel d'empreintes Agilly.

Cadre méthodologique MITRE ATT&CK

- T1562.001 (*Impair Defenses: Disable or Modify Tools*), arrêt forcé et altération logicielle d'agents de protection.
- T1068 (*Exploitation for Privilege Escalation*), élévation du mode utilisateur vers le mode noyau.
- T1547.006 (*Boot or Logon Autostart Execution: Kernel Modules and Extensions*), chargement d'un pilote en mode noyau.

Microsoft Learn, Sécurité Windows

- « *Microsoft Vulnerable Driver Blocklist* », durcissement et application des listes de révocation de pilotes.

Licence et attribution

Le référentiel d'empreintes Agilly est une œuvre dérivée de LOLDrivers (magicword-io, Apache 2.0) et de la transformation de la blocklist Microsoft publiée par Cyb3r-Monk (MIT). Il est redistribué sous Apache 2.0 ; les attributions figurent dans le fichier NOTICE du dépôt. ATT&CK® est une marque déposée de The MITRE Corporation, qui n'est associée en aucune manière à cet outil.

AGILLY CYBERDÉFENSE

Expertise, Détection & Architecture de Résilience

✉ infos@agilly.net www.agilly.net